

1. DoS/DDoS Concepts

What is a DoS Attack?

- **Denial-of-Service (DoS):** An attack on a computer or network that reduces, restricts, or prevents accessibility of system resources to its legitimate users.
- Attackers flood the victim system with non-legitimate service requests or traffic to overload its resources.
- **Goal:** To make the system unavailable to legitimate users, not necessarily to gain unauthorized access or corrupt data.
- **Impact:** Loss of goodwill, network outages, financial losses, operational disruptions, potential data destruction.
- **Examples:** Flooding with traffic, overloading services, crashing TCP/IP stacks with corrupt packets, causing infinite loops, consuming resources (bandwidth, disk space, CPU time).

What is a DDoS Attack?

- **Distributed Denial-of-Service (DDoS):** A large-scale, coordinated DoS attack launched indirectly through multiple compromised computers (**botnets**) on the Internet.
- Uses many compromised computers (**zombies**) to launch a coordinated attack, making it difficult to trace the original attacker.
- **Primary objective:** Gain administrative access on as many systems as possible, then launch coordinated attacks.
- The attack is amplified significantly due to the large number of sources.

How DoS/DDoS Attacks Work (General Flow)

1. Attacker compromises multiple systems (secondary victims) and turns them into **zombie agents** or **bots**.
2. These bots form a **botnet** controlled by the attacker via a **Command and Control (C&C) server**.
3. The attacker sends commands to the bots.
4. Bots flood the primary target system with connection requests or malicious traffic, often using **spoofed IP addresses** to hide their true origin and amplify the attack via **reflector systems**.
5. The target system is overwhelmed, leading to denial of service.

Botnets

- A network of compromised computers (bots or zombies) controlled by an attacker to perform malicious tasks.
- Can be used for DDoS attacks, spamming, spreading malware, sniffing traffic, keylogging, installing advertisement add-ons, crypto-mining.

- **Hierarchical Setup (Cybercrime Syndicates):** Often involves a "Criminal Boss" (entrepreneur), "Underboss" (Trojan provider, C&C manager), "Campaign Managers" (distribute Trojans), and "Stolen Data Resellers."

Scanning Methods for Finding Vulnerable Machines (for Botnets)

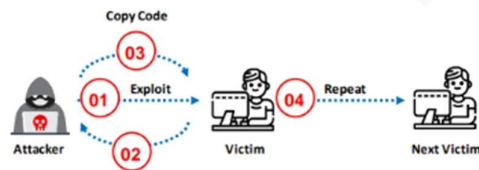
- **Random Scanning:** Bots randomly probe IP addresses within a target network range for vulnerabilities.
- **Hit-list Scanning:** Attackers collect a list of potentially vulnerable machines and target them.
- **Topological Scanning:** Uses information obtained from an infected machine to find new vulnerable machines.
- **Local Subnet Scanning:** Searches for new vulnerable machines in its local network.
- **Permutation Scanning:** Uses a pseudorandom permutation list of IP addresses to find new vulnerable machines.

How Does Malicious Code Propagate?

Attackers use three techniques to propagate malicious code to newly discovered vulnerable systems

Attackers place an **attack toolkit on the central source**, and a copy of the attack toolkit is transferred to the newly discovered vulnerable system

Central Source Propagation



Back-chaining Propagation

An attacker places an **attack toolkit on his/her own system**, and a copy of the attack toolkit is transferred to the newly discovered vulnerable system

The attacking **host itself** transfers the attack toolkit to the newly discovered vulnerable system **at the exact time that it breaks** into that system

Autonomous Propagation



DDoS Case Study: DDoS attack on github

- The world's largest DDoS attack ever recorded
- Take place on Wed, 28 Feb 2018
- Make github's service unavailable for 4 min
- An amplification attack using a Memcached-based approach that peaked at 1.35Tbps

Use of Mobile Devices as Botnets for Launching DDoS Attacks

- Android devices are passively vulnerable to various malware such as Trojan, bots, and RATs, which are often found in third-party application stores
- These unsecured Android devices are becoming primary targets for attackers to enlarge their botnet because they are highly vulnerable to malware
- Malicious Android applications found in the Google Play store and drive-by downloads are just a few examples of infection methods
- The attacker binds the malicious APK server to the Android application package (APK file), encrypts

it, and removes unwanted features and permissions before distributing the malicious package to a third-party app store like the Google Play Store

- Once the user is tricked into downloading and installing such an application, the attacker can gain full control of the victim's device, enslaving the targeted device into the attacker's mobile botnet to perform malicious activities such as launching DDoS attacks and web injections

Basic Categories of DoS/ DDoS Attack **Vectors**

Volumetric Attacks	Protocol Attacks	Application Layer Attacks
• Consume the bandwidth of a target network or service • The magnitude of attack is measured in bits-per-second (bps) • Types of bandwidth depletion attacks: • Flood attacks • Amplification attacks	• Consume other types of resources like connection state tables present in network infrastructure components such as load-balancers, firewalls, and application servers • The magnitude of attack is measured in packets-per-second (pps)	• Consume the resources or services of an application, thereby making the application unavailable to other legitimate users • The magnitude of attack is measured in requests-per-second (rps)
Attack Techniques	Attack Techniques	Attack Techniques
• UDP flood attack • ICMP flood attack • Ping of Death and Smurf attack • Pulse wave and zero-day attack • NTP amplification attack	• SYN flood attack • Fragmentation attack • Spoofed session flood attack • ACK flood attack • TCP SACK panic attack	• HTTP GET/POST attack • Slowloris attack • UDP application layer flood attack • DDoS extortion attack

DoS/DDoS Attack Techniques

- **UDP flood attack**
 - An attacker sends **spoofed UDP packets** at a very high packet rate to a remote host on random ports of a target server using a target src IP range
 - The flooding of UDP packets causes the server to repeatedly check for **non-existent applications** at the ports
 - Legitimate apps are inaccessible by the system and give an error reply with an ICMP
- **ICMP flood attack**
 - A type of attack in which attackers send large volumes of **IMCP echo request packets** to a victim system directly or through relection networks
 - These packets signal the victim's system to reply, and the resulting combination of traffic saturates the bandwidth of the victim's network connection, causing it to be overwhelmed and subsequently stop responding to legitimate TCP/IP requests
 - To protect against this attack, set a threshold limit that invokes an ICMP attack protection feature when exceeded
- **PoD (Ping of Death) attack**
 - An attacker tries to crash,destabilize, of freeze the targeted system or service by sending malformed or oversized packets using a simple ping command
 - Ex: Send a packet which has a size of 65538 bytes
- **Smurf attack**

- Spoof the source IP address with the victim's IP address and sends a large number of ICMP echo request packets to an IP broadcast network
- Cause all the hosts on the broadcast network to respond to the received ICMP echo request. These responses will be sent to the victim machine, ultimately causing the machine to crash
- **Pulse wave attack**
 - Attackers send a **highly repetitive periodic train of packets as pulses** to the target victim every 10 minutes, and each specific attack session can last for a few hours to days.
 - A single pulse (300 Gbps or more) is sufficient to cccrowd a network pipe
- **Zero-day attack**
 - This attack is delivered before the DDoS vulnerabilities of a system have been patched or effective defensive mechanisms are implemented
- **NTP Amplification Attack**
 - In an NTP amplification attack, the attacker uses a botnet to send large UDP packets through a spoofed IP address to the NTP server
 - This attack is often initiated through an NTP server that has its monlist command enabled
 - Each UDP packet triggers a request to the NTP server via the monlist command, which results in the production of large response packets
- **SYN flood attack**
 - Send a large number of SYN requests with fake source IP addresses to the target
 - Take advantage of a flaw in the implementation of the TCP three-way-handshake in most hosts
 - When server receives the SYN request, it must keep track of the partially opened connection in a listen queue for at least **75 seconds**.
 - Countermeasures: Proper packet filtering
- **Fragmentation attack**
 - Stop a victim from being able to re-assemble fragmented packets by flooding the target system with TCP or UDP fragments. Attackers send a larger number of fragmented packets to a target web server with a relatively small packet rate
 - Ressembling and inspecting these large fragmented packets consumes excessive resources. Moreover, the content in the packet fragments will be randomized by the attacker, which in turn makes the process consume more resources
 - **"Destination Unreachable" packet**
- **Spoofed session flood attack**

- Attackers create fake or spoofed TCP sessions by carrying multiple SYN, ACK, and RST or FIN packets
- Attackers employ this attack to bypass firewalls and perform DDoS attacks against target network, exhausting its network resources
- Multiple SYN-ACK Spoofed Session Flood Attack: Create a fake session with multiple SYN and multiple ACK packets along with one or more RST or FIN packets
- Multiple ACK Spoofed Session Flood Attack: Attackers create a fake session by completely skipping the SYN packets and using only multiple ACK packets along with one or more RST or FIN packets
- **HTTPS GET/POST attack**
 - HTTP GET attack: Use a time-delayed HTTP header to maintain HTTP connection and exhaust web server resources
 - HTTP POST attack: Send HTTP requests with complete headers but with incomplete message bodies to the target, prompting the server to wait for the rest of the message body,
- **Slowloris attack**
 - Send partial HTTP requests to the target
 - Upon receiving the partial HTTP requests, the target opens multiple open connections and keeps waiting for the request to complete
 - These requests will not be complete, and the target server's maximum concurrent connection pool will be exhausted, and additional connection attempts will be **denied**.
- **User Datagram Protocol (UDP) flood attack: Generic UDP flood.**
- **Multi-vector attack**

Use combinations of volumetric, protocol, and application-layer attacks to disable the target
- **Peer-to-peer attack**

Attackers instruct clients of peer-to-peer file sharing hubs to disconnect from their peer-to-peer network and to connect to the victim's fake website

Exploits flaws found in the network using the DC++ (Direct Connect) protocol, which is used for sharing all types of files between instant messaging clients

Attacks launch massive DoS and compromise websites.
- **Permanent DoS (PDoS) attack**

Phlashing: Permanent DoS, also known as plashing, refers to attacks that cause irreversible damage to system hardware

Sabotage: Unlike other DoS attacks, it sabotages the system hardware, requiring the victim to replace or reinstall the hardware

Bricking a system: This attack is carried out using a method known as bricking a system. Using this method, attackers send fraudulent hardware updates to the victims

- **TCP SACK Panic Attack**
In TCP SACK panic attack, attackers attempt to crash the target Linux machine by sending SACK packets with malformed maximum segment size (MSS)
 - This attack exploits an integer overflow vulnerability in Linux Socket Buffer (SKB), which can lead to kernel panic
 - Attackers send SACK packets in sequence to the target server by setting MSS to the lowest value (48 bytes)
 - The socket buffer exceeds the limit and triggers integer overflow causing a kernel panic that leads to denial of service
- **Distributed reflection DoS (DRDoS) attack**
Also known as a spoofed attack, involves the use of multiple intermediary and secondary machines that contribute to the actual DDoS attack against the target machine or application. Launch this attack by sending requests to the intermediary hosts, which then redirect the requests to the secondary machines, which in turn reflect the attack traffic to the target.
Adv: The primary target seems to be directly attacked by the secondary victim rather than the actual attacker. Multiple intermediary victim servers are used, which results in an increase in attack bandwidth.
Countermeasure: Turn off the CHARGEN (Character Generator Protocol) service to stop this attack method.

DoS/ DDoS Attack Toolkits in the Wild

ISB (I'm so bored) is a software utility that helps attackers to perform HTTP, UDP, TCP and ICMP flood attacks on the target network

UltraDDoS-v2 provides a simple GUI interface where attackers can enter target IP address, port number and number of packets that they desire to transmit

- **High Orbit Ion Cannon (HOIC):** Flood tool for HTTP GET/POST.
- **Low Orbit Ion Cannon (LOIC):** Simple DoS tool.
- **HULK:** HTTP Unbearable Load King (HTTP flood).
- **Slowloris:** Layer 7 HTTP DoS tool.
- **UFONet:** Uses "zombies" to create/manage botnets and perform DoS/DDoS.
- **Packet Flooder Tool:** Generic packet flooding tool.

4. DoS/DDoS Attack Countermeasures

Mitigating DoS/DDoS attacks requires a multi-layered approach involving detection, prevention, and response.

Detection Techniques

- **Activity Profiling:** Monitors average packet rates, network flow clusters.
- **Sequential Change Detection:** Identifies abnormal traffic patterns that deviate from normal behavior.
- **Wavelet-Based Signal Analysis:** Analyzes statistical properties of traffic for anomalies.

- **Traffic Pattern Analysis:** Identifies characteristics of incoming traffic.
- **Packet Traceback:** Traces packets back to their source.
- **Event Log Analysis:** Identifies DoS/DDoS attacks and their sources from logs.

DoS/DDoS Countermeasure Strategies

- **Absorbing the Attack:** Increasing capacity to handle attack traffic (e.g., Load Balancing, Throttling).
- **Degrading Services:** Maintain critical service functionality while shedding non-critical services.
- **Shutting Down Services:** Shutting down all services until the attack has subsided (last resort).

Protecting Secondary Victims (for DDoS)

- **Monitor for DDoS Agent Software:** Regularly scan and remove agent software.
- **Anti-virus/Anti-Trojan software:** Keep up-to-date.
- **Security Patches/Updates:** Increase awareness, keep systems patched.
- **Disable Unnecessary Services/Scans:** Remove unused applications and scan all files.
- **Hardened Systems:** Properly configure hardware/software for defense.

Detecting and Neutralizing Handlers

- **Network Traffic Analysis:** Analyze C&C traffic patterns.
- **Neutralize Botnet Handlers:** Disrupt C&C servers.
- **Spoofed Source Address Prevention:** Block packets with invalid source addresses (e.g., Egress Filtering).

Preventing Potential Attacks

- **Egress Filtering:** Filters outgoing packets at network boundaries to prevent spoofed IP addresses from leaving the network.
- **Ingress Filtering:** Filters incoming packets to ensure source addresses are legitimate.
- **TCP Intercept:** Router feature that protects TCP servers from SYN flood attacks by intercepting SYNs and completing handshakes.
- **Rate Limiting:** Controls the volume of inbound traffic to prevent network overflow.
- **Honeypots:** Decoy systems designed to lure attackers and collect information about attack methods without affecting production systems.

Mitigate Attacks (Load Balancing, Throttling, Drop Requests)

- **Load Balancing:** Distributes incoming traffic across multiple servers to prevent overload.
- **Throttling:** Limiting inbound traffic to prevent resource exhaustion.
- **Drop Requests:** Discarding requests when server load is too high.

Post-Attack Forensics

- **Traffic Pattern Analysis:** Analyze attack traffic to identify characteristics and update defenses.
- **Packet Traceback:** Trace attack traffic back to its source.
- **Event Log Analysis:** Analyze logs to identify DoS/DDoS attacks.

Defending against Botnets

- **RFC 3704 Filtering (Unicast Reverse Path Forwarding - uRPF):** Basic access-control list filter that limits DDoS attacks from spoofed source addresses.
- **Cisco IPS Source IP Reputation Filtering:** Uses reputation services to identify and block known botnet/malware IPs.
- **Black Hole Filtering:** Discards undesirable traffic by routing it to a "null0" interface.
- **DDoS Prevention Offerings from ISP or DDoS Service:** ISPs offer managed DDoS protection.

DDoS Protection at ISP Level

- ISPs provide "clean pipes" services, filtering malicious traffic before it reaches the customer network.
- Redirect attack traffic to ISP's scrubbing centers.

Advanced DDoS Protection Appliances/Tools

- **FortiDDoS:** Machine learning-based DDoS mitigation.
- **Quantum DDoS Protector (Check Point):** Multi-layered protection, behavioral analysis.
- **Huawei AntiDDoS1000:** Big Data analytics for large-scale attacks.
- **A10 Thunder TPS:** Ensures reliable access to key network services.
- **Anti DDoS Guardian:** Protects IIS, Apache, mail servers from DDoS attacks.
- **DDoS-GUARD, Radware DefensePro, Gatekeeper, F5 DDoS Attack Protection.**

DDoS Protection Services (Cloud-based)

- **Cloudflare:** Provides DDoS mitigation via a global network, BGP-based protection, L7 services.
- **Akamai DDoS Protection:** Leverages dedicated infrastructure to safeguard internet-facing applications.
- **Stormwall PRO, Imperva DDoS Protection, Nexusguard, BlockDoS.**

Key Terms for Last-Minute Revision

- **DoS (Denial-of-Service):** Attack to make a resource unavailable.
- **DDoS (Distributed Denial-of-Service):** DoS attack from multiple sources.
- **Botnet:** Network of compromised computers (bots/zombies).

- **Zombie/Bot:** A compromised computer in a botnet.
- **C&C (Command and Control) Server:** Server used by attacker to control botnet.
- **Volumetric Attack:** Overloads bandwidth (e.g., UDP Flood, ICMP Flood, Smurf, NTP Amplification).
- **Protocol Attack:** Consumes server/network device resources (e.g., SYN Flood, Fragmentation, Ping of Death).
- **Application Layer Attack:** Targets specific application flaws (e.g., HTTP GET/POST Flood, Slowloris).
- **SYN Flood:** Exploits TCP three-way handshake by leaving half-open connections.
- **Smurf Attack:** Amplified ICMP flood using broadcast addresses.
- **NTP Amplification:** Uses NTP servers to amplify traffic to victim.
- **Slowloris:** Keeps HTTP connections open with partial requests to exhaust server resources.
- **PDOS (Permanent Denial-of-Service) / Phlashing:** Irreparably damages hardware/firmware.
- **DRDoS (Distributed Reflection DoS):** Uses third-party "reflectors" to bounce traffic to the victim.
- **DDoS Extortion (RDDoS):** Ransomware variant demanding payment to stop a DDoS attack.
- **Egress Filtering:** Filters outgoing traffic to prevent IP spoofing.
- **Ingress Filtering:** Filters incoming traffic to ensure legitimate source IPs.
- **TCP Intercept:** Router feature to protect against SYN floods.
- **Rate Limiting:** Controls traffic volume.
- **Honeypots:** Decoy systems to lure attackers and gather intel.
- **Load Balancing:** Distributes traffic across multiple servers.
- **Throttling:** Limits traffic to a server.
- **Traffic Pattern Analysis:** Detecting anomalies in network traffic.
- **Packet Traceback:** Tracing attack packets to their source.
- **RFC 3704 Filtering:** Basic ACL for spoofed IP packets.
- **Black Hole Filtering:** Discarding unwanted traffic.
- **DDoS Protection Services (Cloud-based):** Cloudflare, Akamai, etc.
- **DDoS Protection Appliances:** FortiDDoS, Quantum DDoS Protector, A10 Thunder TPS.